

SecureOrg Inc.

PCI DSS Compliance Framework

Incident Response Policy

Document Reference:	IRP-009
Version:	2.1
Effective Date:	April 14, 2026
Document Owner:	Chief Information Security Officer
Classification:	CONFIDENTIAL
Review Cycle:	Annual
Framework:	PCI DSS v4.0

This document contains confidential and proprietary information. Unauthorized disclosure is prohibited.

1. Purpose and Scope

1.1 Purpose

This Incident Response Policy establishes SecureOrg Inc.'s framework for preparing for, detecting, containing, eradicating, recovering from, and learning from information security incidents, with particular focus on incidents affecting cardholder data. The Policy implements PCI DSS v4.0 Requirement 12.10 (Respond Immediately to System Breaches), ensuring a structured, timely, and effective response to security events.

1.2 Scope

This Policy applies to all security incidents affecting company information systems, with mandatory escalation procedures for incidents involving or potentially involving cardholder data or the cardholder data environment.

1.3 Definitions

Security Event: Any observable occurrence in a system or network. Not all events are incidents.

Security Incident: A violation or imminent threat of violation of this or related security policies, or a situation where unauthorized access to, disclosure of, or compromise of information assets has occurred or is suspected.

CHD Breach: An incident confirmed to involve unauthorized access to, acquisition of, or disclosure of cardholder data.

2. Incident Response Team

2.1 Incident Response Team (IRT)

The Incident Response Team is responsible for managing security incidents. The IRT has the following composition:

Incident Commander	Overall incident management and decision-making	CISO
Security Lead	Technical investigation and containment	Senior Security Analyst
IT Operations Lead	System recovery and remediation implementation	IT Operations Manager
Legal Counsel	Legal advice, regulatory notification guidance	General Counsel
Communications Lead	Internal and external communications	VP Communications
Privacy Officer	Data subject notification requirements	CPO/DPO
Business Unit Representative	Business impact assessment and recovery prioritization	BU Director

2.2 External Resources

The organization maintains contracts and contact information for the following external resources:

- PCI Forensic Investigator (PFI): Engaged for confirmed or suspected CHD breaches
- External legal counsel specializing in data breach response
- Cyber insurance carrier 24/7 hotline
- Payment brand security contacts (Visa, Mastercard, Amex, Discover, JCB)
- Law enforcement contacts (FBI, Secret Service for financial crime)

3. Incident Classification

3.1 Severity Levels

Critical (P1)	Active breach or imminent threat to CHD	Active intrusion in CDE; confirmed CHD exfiltration; ransomware in CDE	15 minutes
High (P2)	Significant threat with potential CHD impact	Malware detected in CDE; unauthorized privileged access; DDoS impacting CHD systems	1 hour
Medium (P3)	Security incident without confirmed CHD impact	Phishing campaign; failed intrusion; security control failure	4 hours
Low (P4)	Minor policy violation or anomalous activity	Acceptable use violation; single failed authentication anomaly	24 hours

3.2 CHD Incident Indicators

The following indicators must trigger immediate escalation to a P1 or P2 incident:

- IDS/IPS alerts for known payment card attack signatures in CDE
- Unusual outbound data transfers from CDE systems
- Access to CHD databases outside of normal business hours
- Detection of card-skimming malware or tools
- Reports from card brands or customers of fraudulent activity on cards processed at SecureOrg
- Discovery of CHD in unexpected locations (unencrypted, outside the CDE)
- Payment terminal anomalies suggestive of tampering

4. Incident Response Process

4.1 Phase 1: Preparation

Preparation activities that must be maintained continuously:

- Incident response procedures, contact lists, and playbooks reviewed and updated annually
- Incident response tabletop exercises conducted at least annually (PCI DSS Req 12.10.6)
- CDE systems have 24/7 security monitoring with alerts routed to the on-call security analyst

- Digital forensics tools and forensic workstations maintained in ready state
- Forensic evidence collection procedures documented and tested
- Secure, isolated network segment available for forensic analysis

4.2 Phase 2: Detection and Analysis

Upon receipt of a potential incident alert or report:

- Assign a unique incident tracking ID and log in the incident management system
- Conduct initial triage to determine if the event constitutes an incident and assign preliminary severity
- Notify the Incident Commander for P1/P2 incidents; assemble IRT
- Preserve evidence: capture logs, take system snapshots, document everything with timestamps
- Determine scope: which systems are affected, is CHD involved, what data may be at risk
- Conduct forensic analysis to determine attack vector, timeline, and extent of compromise
- Update incident severity classification based on analysis findings

4.3 Phase 3: Containment

Containment strategies must balance security (stopping the threat) with business continuity:

- Short-term containment: Isolate affected systems from the network to prevent further compromise; preserve evidence
- Evidence preservation: Prior to any remediation, image affected systems and preserve logs in write-once storage
- Long-term containment: Implement temporary fixes (patch, access revocation, rule changes) to allow business to continue securely
- For CHD breaches: immediately notify payment brands per contractual obligations (typically within 24 hours of confirmation)
- Prevent destruction of evidence: do not reboot or wipe systems involved in a CHD breach without PFI guidance

5. Notification Requirements

5.1 Internal Notifications

P1 – Critical	CISO, CEO, CTO, Legal, Board (if CHD breach)	15 minutes

P2 – High	CISO, CTO, Legal	1 hour
P3 – Medium	CISO, relevant business unit head	4 hours
P4 – Low	Security Manager	24 hours

5.2 External Notifications (CHD Breach)

For confirmed or suspected CHD breaches, the following external notifications are required:

- Acquiring bank: Notify immediately upon confirmation; provide incident details and preliminary scope
- Payment card brands (Visa, Mastercard, etc.): Notify within 24 hours per card brand rules
- PCI Forensic Investigator (PFI): Engage within 24 hours of confirmed CHD breach
- Law enforcement (FBI): At organization's and legal counsel's discretion
- Regulatory bodies: As required by applicable law (GDPR 72 hours; various state laws)
- Affected individuals: As required by applicable breach notification laws
- Cyber insurance carrier: Per policy requirements

5.3 Notification Prohibitions

The following are prohibited without explicit Legal Counsel approval:

- Public statements, press releases, or social media communications about a security incident
- Notification of any party not listed in the notification matrix
- Disclosure of the specific number of potentially affected cardholders during investigation

6. Eradication and Recovery

6.1 Eradication

After containment, eradication removes the root cause of the incident:

- Identify and eliminate malware, unauthorized accounts, backdoors, and other artifacts of the attack
- Determine and remediate the root cause vulnerability (patch, configuration change, access revocation)
- Rebuild affected systems from clean, known-good images where possible
- Change all credentials and secrets that may have been exposed

- Verify eradication through scanning and security assessment before restoration

6.2 Recovery

- Restore systems from clean backups verified as unaffected by the incident
- Monitor restored systems intensively for indicators of re compromise
- Validate system functionality and security controls before resuming CHD processing
- Obtain CISO approval before resuming CHD processing in previously compromised environments

6.3 Post-Incident Activities

Within 30 days of incident closure:

- Conduct formal post-incident review (lessons learned session) with all IRT members
- Document root cause, timeline, actions taken, and their effectiveness
- Identify and implement security improvements to prevent recurrence
- Update incident response procedures, playbooks, and detection rules based on findings
- Brief executive leadership and, where required, the board on findings and improvements

7. Evidence Handling and Forensics

7.1 Evidence Preservation

Proper evidence handling is essential for forensic analysis, legal proceedings, and regulatory compliance:

- All evidence shall be collected and documented using a formal chain of custody form
- Evidence collection must begin before any remediation activities
- System images must be taken using forensically sound methods (write blockers)
- Evidence must be stored in secure, tamper-evident storage
- Hash values of evidence must be recorded to verify integrity
- Evidence must be retained for a minimum of 36 months or as directed by Legal Counsel

7.2 Forensic Investigation

For CHD breach investigations, a PCI Forensic Investigator (PFI) must be engaged. The PFI will:

- Conduct an independent forensic investigation of all systems within the breach scope
- Determine the method of compromise, attack timeline, and data at risk
- Provide a forensic investigation report to the organization and card brands
- Make recommendations for remediation and security improvements

8. Revision History

1.0	Jan 15, 2024	Initial release	CISO Office
2.0	Mar 5, 2025	Major revision: PFI requirements; notification matrix; evidence handling	Security/Legal
2.1	Apr 14, 2026	Annual review; updated notification timelines; MFA fatigue playbook	CISO Office